

Guia da Parte Prática

Security Baseline e Arquitetura Segura

Guia detalhado para os grupos - atividade incremental do Projeto Integrador

Curso Superior de Tecnologia em Desenvolvimento de Software Multiplataforma
ISG-022 - Segurança no Desenvolvimento de Aplicações
20 de agosto de 2026

1. Objetivo da atividade

Nesta prática, o grupo deverá revisar o projeto que foi configurado no GitHub e produzir a primeira baseline de segurança. O objetivo não é implementar todos os controles hoje. O objetivo é identificar o que precisa ser protegido, quais riscos são plausíveis e quais decisões de projeto deverão orientar a evolução da solução.

Entrega ao final da aula

Security Baseline + cenários iniciais de risco + atualização da arquitetura + commit no repositório.

2. Pré-requisitos

- Repositório do grupo criado e acessível no GitHub.
- Papéis do time definidos: 1 PM, 1 Tech Lead e 3 Team Members.
- Descrição mínima do problema/domínio do projeto.
- README inicial e estrutura básica do repositório.
- Ferramenta para editar Markdown e, se possível, uma ferramenta de diagramação (Mermaid, draw.io, Excalidraw, PlantUML ou similar).

3. Organização do time

Papel	Responsabilidade nesta prática
Product Manager	Explicar impacto de negócio, usuários envolvidos, ativos mais valiosos e prioridade dos riscos.
Tech Lead	Conduzir decisões técnicas, fronteiras de confiança, arquitetura e integração no Git.
Team Members	Dividir levantamento de ativos/riscos, propor controles, atualizar documentação e revisar o material.

Regra

O Tech Lead não deve fazer a atividade sozinho. As decisões precisam refletir o raciocínio do grupo.

4. Estrutura sugerida no repositório

```
repo/
├── README.md
├── docs/
│   ├── architecture/
│   │   └── architecture-v1.md      # ou arquivo de imagem/diagrama
│   ├── security/
│   │   ├── security-baseline.md
│   │   └── initial-risks.md
│   └── ...
```

Importante: se o repositório já possui uma organização equivalente, não crie outra estrutura apenas para obedecer ao exemplo. Preserve a organização existente e garanta que os artefatos fiquem localizáveis.

5. Passo 0 - preparar o trabalho no Git

Opção recomendada: criar uma branch específica para a documentação de segurança. Se a turma ainda não estiver confortável com branch/PR, o professor poderá permitir trabalho direto na branch atual.

```
git pull
git checkout -b docs/security-baseline
```

Não deixe o Git consumir a prática

O objetivo da aula é segurança. Se houver problema operacional, documente localmente e faça o push depois.

6. Passo 1 - identificar pelo menos 5 ativos

Ativo é algo que possui valor para usuários, negócio ou operação e que precisa ser protegido. Prefira ativos específicos.

Ativo	Por que tem valor?	CIA/AUT mais relevante	Responsável/componente
Dados cadastrais de clientes	Exposição afeta privacidade e confiança	C + I	Backend / Banco
Credencial administrativa	Permite operações privilegiadas	C + AUT	Admin
API de pedidos	Canal central da operação	I + A	Backend
Código-fonte	Contém lógica e dependências	I + C	Time
Logs de auditoria	Permitem investigar ações e incidentes	I + A	Operação

Perguntas para o grupo

- Se este ativo vazar, o que acontece?
- Se for alterado indevidamente, o que acontece?
- Se ficar indisponível, quem é afetado?
- Precisamos confiar na identidade/origem associada a este ativo?
- Existe um ativo mais específico do que “sistema” ou “dados”?

7. Passo 2 - associar CIA + autenticidade

Propriedade	Pergunta
Confidencialidade	Quem pode acessar? Quem não pode? Há informação que não deveria existir em logs/respostas?

Propriedade	Pergunta
Integridade	Quem pode alterar? Quais regras precisam ser preservadas? Como sabemos que o dado não foi adulterado?
Disponibilidade	Qual indisponibilidade é tolerável? Que dependências podem derrubar o fluxo?
Autenticidade	Como provamos identidade e origem? O sistema diferencia usuário, administrador e serviço?

Dica

Não marque C + I + A + AUT em todos os ativos automaticamente. Priorize as propriedades que realmente dirigem o risco.

8. Passo 3 - construir pelo menos 3 cenários de risco

Use a sequência: Ativo → Ameaça → Vulnerabilidade → Exploração → Impacto → Risco.

Campo	O que escrever	Exemplo
Ativo	O que possui valor	Dados cadastrais
Ameaça	Quem/o que pode causar dano	Atacante externo
Vulnerabilidade	Fraqueza concreta	API não valida autorização por recurso
Exploração	Como a fraqueza é usada	Troca ID e solicita registro de outro usuário
Impacto	Consequência	Exposição de dados de clientes
Risco	Resumo do cenário relevante	Acesso indevido a dados de outros clientes

Erros a evitar

“Hacker” não é vulnerabilidade. “Ataque” não é impacto. “Colocar firewall” não é risco. Use cada campo para uma função específica.

9. Passo 4 - priorizar probabilidade e impacto

Nível	Probabilidade	Impacto
Baixo	Cenário pouco plausível, alta dificuldade ou forte isolamento	Consequência limitada e recuperável
Médio	Cenário plausível com algumas	Impacto relevante, mas contido

Nível	Probabilidade	Impacto
	condições	
Alto	Exposição significativa, facilidade ou poucos controles	Grande dano a dados, serviço, usuários ou negócio

Registre a justificativa. A escala serve para priorizar discussão; não é uma medição científica.

10. Passo 5 - aplicar princípios de projeto seguro

Princípio	Pergunta de revisão
Menor privilégio	Quem possui mais acesso do que precisa?
Defesa em profundidade	Se uma barreira falhar, qual outra ainda protege o ativo?
Redução da superfície de ataque	O que pode ser removido, fechado, restringido ou desabilitado?
Secure by default	O estado inicial é seguro sem configuração extra?
Fail secure	Quando uma dependência falha, o sistema libera ou bloqueia? Qual é o estado seguro?
Fronteiras de confiança	Onde dados/identidades atravessam contextos e precisam ser validados?

11. Passo 6 - transformar princípio em decisão e controle

Elemento	Exemplo
Risco	Usuário acessa registro pertencente a outro usuário.
Princípio	Secure by default + menor privilégio + fronteira de confiança.
Decisão	Backend autoriza cada recurso solicitado; frontend nunca é fonte de decisão de acesso.
Controle	Policy/ACL por recurso + testes de autorização + log de negação.
Efeito esperado	Reduz probabilidade de acesso indevido e aumenta rastreabilidade.
Risco residual	Bug/regra incorreta ainda pode existir; exige revisão e testes.

Teste de qualidade

Para cada controle, responda: “qual risco este controle trata?” Se não houver uma resposta clara, o controle está provavelmente genérico ou deslocado.

12. Passo 7 - atualizar o diagrama de arquitetura

O diagrama não precisa representar cada biblioteca. Ele precisa permitir entender os caminhos relevantes para segurança.

- Usuários, clientes ou integrações externas.
- Frontend, API/gateway, backend, serviços privilegiados.
- Banco(s), storage, filas ou componentes que armazenam/processam ativos críticos.
- Fronteiras de confiança entre Internet, aplicação, dados e serviços externos.
- Controles arquiteturais relevantes: autenticação, autorização, validação, rate limit, segredo, logging, isolamento.
- Fluxos principais entre componentes.

Não faça uma “árvore de Natal”

Não coloque cada possível controle no desenho. Mostre somente o que ajuda a explicar decisões de segurança da arquitetura.

13. Passo 8 - criar security-baseline.md

```
# Security Baseline

## 1. Contexto do sistema
Breve descrição do projeto e dos usuários envolvidos.

## 2. Ativos prioritários
| Ativo | Valor | CIA/AUT | Responsável |
|---|---|---|---|
| ... | ... | ... | ... |

## 3. Princípios adotados
### Menor privilégio
Decisões do projeto...

### Defesa em profundidade
Decisões do projeto...

### Redução da superfície de ataque
Decisões do projeto...

### Secure by default
Decisões do projeto...

### Fail secure
Decisões do projeto...

### Fronteiras de confiança
Decisões do projeto...

## 4. Riscos residuais e premissas
- ...
```

```
## 5. Próximos passos
```

```
- ...
```

14. Passo 9 - criar initial-risks.md

```
# Initial Security Risks

| ID | Ativo | Ameaça | Vulnerabilidade | Impacto | Prob. | Impacto | Risco | Controles / Decisões | Residual |
|---|---|---|---|---|---|---|---|---|---|
| R-01 | ... | ... | ... | ... | M | A | Alto | ... | ... |
| R-02 | ... | ... | ... | ... | B | M | Baixo | ... | ... |
| R-03 | ... | ... | ... | ... | A | A | Alto | ... | ... |
```

15. Passo 10 - commit, push e revisão

```
git status
git add docs/security docs/architecture
git commit -m "docs(security): add initial security baseline"
git push -u origin docs/security-baseline
```

Se houver tempo, abra um Pull Request e peça para outro membro do grupo revisar se existe relação explícita entre risco, princípio e decisão.

16. Exemplo completo de um cenário

Campo	Preenchimento exemplo
Ativo	Dados cadastrais de clientes
CIA/AUT	Confidencialidade + Integridade
Ameaça	Usuário malicioso autenticado
Vulnerabilidade	Endpoint consulta registro pelo ID sem verificar se o registro pertence ao usuário
Exploração	Usuário altera o ID na requisição
Impacto	Acesso a dados de outros clientes; possível exposição em escala
Probabilidade	Média - endpoint é acessível a todo usuário autenticado
Impacto	Alto - exposição de dados e perda de confiança
Princípios	Secure by default; menor privilégio; fronteira de confiança; defesa em profundidade
Decisão	Backend verifica autorização por recurso e nega por padrão

Campo	Preenchimento exemplo
Controles	Policy/ACL; testes negativos; logs de negação; API retorna apenas campos necessários
Residual	Erro de regra/configuração; deve ser reduzido com testes e revisão

17. Definition of Done da prática

- ☐ O grupo identificou pelo menos 5 ativos específicos.
- ☐ Cada ativo possui justificativa de valor e propriedades CIA/AUT relevantes.
- ☐ Existem pelo menos 3 cenários completos de risco.
- ☐ Ameaça e vulnerabilidade foram diferenciadas corretamente.
- ☐ Probabilidade e impacto possuem justificativa.
- ☐ Há decisões ligadas a princípios de projeto seguro.
- ☐ Os controles tratam riscos identificados, não são uma lista genérica.
- ☐ O diagrama evidencia componentes e fronteiras relevantes.
- ☐ Security Baseline e riscos estão versionados no repositório.
- ☐ Existe um commit identificável da atividade.

18. Critérios de qualidade

Critério	Fraco	Adequado	Excelente
Ativos	Genéricos e sem valor claro	Específicos e relacionados ao domínio	Priorizados e ligados a impacto/owner
Riscos	Termos misturados e genéricos	Cenários completos e plausíveis	Cenários claros, priorizados e contextualizados
Princípios	Lista sem aplicação	Princípios ligados às decisões	Trade-offs e risco residual explicitados
Arquitetura	Somente componentes funcionais	Fronteiras e controles relevantes	Responsabilidades, fluxos e justificativas claras
Git/documentação	Arquivos soltos	Estrutura organizada e commit claro	Histórico, revisão e rastreabilidade das decisões

19. O que não fazer

- Não copiar uma checklist de segurança pronta sem relacionar ao sistema.
- Não tratar “firewall”, “criptografia” ou “MFA” como respostas universais.

- Não chamar ameaça de vulnerabilidade ou vice-versa.
- Não tentar implementar tudo hoje; o objetivo é baseline e decisões.
- Não colocar segredos, tokens ou credenciais reais nos exemplos/documentos.
- Não desenhar uma arquitetura irreal apenas para “parecer segura”. Registre o estado e a evolução planejada.

20. Fechamento do grupo

- Qual ativo foi mais crítico?
- Qual risco mudou uma decisão de arquitetura?
- Qual princípio foi mais difícil de aplicar?
- Qual risco residual o grupo aceitou temporariamente?
- Qual será o primeiro item de segurança a evoluir na próxima Sprint?

Resultado esperado

Ao terminar, qualquer pessoa que leia o repositório deve conseguir entender o que o grupo considera valioso, quais são os riscos iniciais e quais decisões de segurança orientarão a evolução do projeto.